

DOCUMENTO ARCHITETTURALE DEFINITIVO

bAlt Agent × NetSuite — Registrazione Vendor Bill

Cliente Alfa · Pattern A (Qdrant + Portale)

Versione 1.0 · Bozza riservata

Documento anonimizzato per condivisione esterna

Obiettivo

Integrazione sicura tra **bAlt Agent** e NetSuite per la registrazione di **Vendor Bill**, nel rispetto del vincolo di **human-in-the-loop** e con garanzia di assoluta integrità dei dati contabili. Il documento descrive l'architettura di riferimento, il flusso operativo in quattro step e i presidi di sicurezza e compliance.

1. Architettura di Riferimento

Il progetto implementa il **Pattern A** (Qdrant + Portale), articolato nei seguenti componenti:

Componente	Tecnologia	Ruolo
Frontend — BaitPortal	Node.js (porta 3000)	Gestione UI, upload e “Safety Zone” visiva
Backend — VaultAI	FastAPI (porta 8088)	Orchestrazione retrieval e integrazione NetSuite
Vector store	Qdrant	Retrieval contestuale per tenant (regole, conti)
ERP	NetSuite — SuiteTalk REST	Anagrafica fornitori e registrazione Vendor Bill
Isolamento	client_id=clientalfa, env=demo	Accesso alla sola collection demo_clientalfa_...

Isolamento tenant. Ogni richiesta verso il backend include `client_id=clientalfa` ed `env=demo`, in modo da interrogare esclusivamente la collection Qdrant dedicata (`demo_clientalfa_...`).

2. Flusso Operativo (Step-by-Step)

Il processo è suddiviso in quattro step isolati per massimizzare sicurezza e tracciabilità.

Step 1 — Ingestione e Pre-processing (OCR + LLM)

- L'utente carica il PDF della fattura tramite la chat del **BaitPortal**.
- Il backend applica uno strato di parsing/OCR per convertire il documento in testo strutturato prima dell'analisi semantica.
- Il modello LLM elabora il testo assegnando un **punteggio di confidenza** a ogni entità estratta. I campi sotto soglia (es. Partita IVA poco leggibile) vengono inseriti nel payload con un flag di **“revisione manuale obbligatoria”**.

Step 2 — Estrazione Profonda e Validazione (REST API)

- Il sistema interroga Qdrant per estrarre le regole di reparto (es. conti di spesa) e compila un dataset completo: testata, righe di costo, aliquote IVA, subsidiary e termini di pagamento.

- **Coerenza di canale.** FastAPI interroga NetSuite esclusivamente tramite le API REST (SuiteTalk) con **Token-Based Auth**, in sola lettura.
- **Match fornitore.** La ricerca avviene rigorosamente per **Partita IVA / Tax ID**, non per nome. Se il fornitore non viene trovato, l'agente **sospende il processo** e notifica l'eccezione in chat, senza creare automaticamente nuove anagrafiche.

Step 3 — Safety Zone e Gestione Stato Server-Side

- FastAPI valida la **quadratura matematica** della fattura (somma righe + IVA = totale documento).
- Il backend salva la bozza nel proprio stato interno generando un **draft_id** univoco; il **draft_id** e il payload editabile vengono inviati al BaitPortal.
- La UI si divide: a sinistra il PDF originale, a destra il form da revisionare.
- **Zero-Trust.** Il frontend non è considerato fonte di verità. L'utente non può alterare parametri di sistema (es. Vendor Internal ID) e ogni modifica manuale ai campi viene **ri-validata dal server** prima della persistenza sulla bozza.

Step 4 — Esecuzione Sicura, Idempotenza e Audit

- L'utente clicca esplicitamente il pulsante di approvazione (**human-in-the-loop**).
- Il frontend restituisce a VaultAI il solo **draft_id**: i dati autorevoli risiedono già server-side.
- FastAPI applica una **idempotency key deterministica** (derivata da numero fattura + ID fornitore) e fa un controllo preventivo (GET) su NetSuite per assicurarsi che la fattura non sia già registrata, azzerando il rischio di duplicati contabili.
- Viene eseguita l'**operazione di scrittura (POST)** sulla Vendor Bill API di NetSuite.
- **Audit Log.** L'operazione viene registrata nei log di sicurezza includendo non solo l'azione dell'agente, ma l'**identificativo dell'operatore umano** che ha fornito l'approvazione. Eventuali errori o rifiuti di NetSuite vengono catturati e gestiti graficamente nel portale per consentire un nuovo tentativo.

3. Compliance e Sicurezza

- **Human-in-the-loop garantito.** Nessuna POST viene eseguita senza il click esplicito di approvazione dell'operatore.
- **Autorizzazione e ruoli.** Oltre all'autenticazione, il portale verifica che l'utente abbia il **ruolo abilitato** all'approvazione; l'audit registra chi ha approvato.
- **Isolamento tenant.** Il routing su FastAPI assicura il retrieval sulla sola collection Qdrant dedicata (**demo_clientalfa_...**).
- **Idempotenza e integrità.** Controllo preventivo + idempotency key impediscono duplicati; la quadratura matematica blocca fatture incoerenti.
- **Gestione segreti.** Credenziali NetSuite e token sono conservati come variabili d'ambiente lato server, mai esposti al frontend né in file in chiaro.
- **Protezione dei dati (GDPR).** I PDF caricati contengono dati personali: vanno applicate policy di retention/cancellazione e cifratura at-rest dei documenti e delle bozze.